

Meeting 20/05/2026

Summary

Action Items & Next Steps

- ❑ Configure Kalico as CNI; audit sidecar injection on all workloads; complete Istio setup on RKE2
- ❑ Set up ArgoCD for GitOps CD; configure Rancher for multi-cluster management across dev and production
- ❑ Write Terraform manifests for all infrastructure; no manual changes in the production cluster
- ❑ Evaluate and integrate WAF (open-appsec, SafeLine CE, or Cloudflare CE) and NeuVector for DPI; route breach events to the notification service
- ❑ Build a reference microservice with multiple sidecars, Loki log shipping, WAF, DPI, and notification service
- ❑ Set up Security Admin persona in Keycloak with access to WAF logs, DPI reports, Loki streams, and Jenkins
- ❑ Integrate feature flag tool: Unleash, Flagsmith, or OpenFeature as a self-hosted LaunchDarkly alternative
- ❑ Implement ML-agent verification in the KYC flow via Kafka; provision approved users in Keycloak with general or premium role
- ❑ Implement backup and recovery: mongodump to MinIO, VolumeSnapshot for PVCs, CronJob dump to S3; define PVC manifests for all StatefulSets
- ❑ Produce architecture diagram for the full security and observability stack

Concepts Discussed

Cluster Networking and CNI

- Kalico (rebranded Calico) chosen as CNI for eBPF-based network policy enforcement; Flannel reviewed as a simpler alternative
- Sidecar audit required: WAF and DPI integrations depend on Istio sidecar proxies being present in each pod

Cluster Management: ArgoCD, Rancher, and Terraform

- ArgoCD continuously reconciles cluster state with Git; Rancher provides multi-cluster RBAC and management UI across dev and production
- All provisioning managed via Terraform; dev cluster for unstable workloads, production cluster gated by the full CI/CD pipeline

Web Application Firewall and DPI

- WAF options: open-appsec (ML-based), SafeLine CE (lightweight), Cloudflare CE; NeuVector provides DPI for payload and protocol inspection
- Suricata reviewed as an open-source IDS/IPS complement; firewall layered across network (mTLS, DPI, rate limiting, IP blocking) and application (WAF ingress rules) levels

Security Admin Persona and Observability Integration

- Keycloak Security Admin role grants access to WAF, DPI, Loki, and Jenkins audit logs from a single SSO session
-

-
- Logs routed through Kafka topics before Loki ingestion; Loki deployed on RKE2 with Prometheus Operator; breach events sent to SHIM notification service via webhook

Feature Flags: LaunchDarkly and Open-Source Alternatives

- Unleash: self-hosted, Kubernetes-native, RBAC and audit logs
- Flagsmith: self-hosted, user segmentation and RBAC; OpenFeature: CNCF vendor-neutral API that plugs into Unleash or Flagsmith as the backend

ML-Agent-Assisted User Verification

- New user submits KYC form; event published to Kafka; ML agent scores submission and pre-approves or flags for human admin review
- Approved users provisioned in Keycloak via admin REST API with general or premium role; group-based admin model used for shared verification workload

Backup, Recovery, and Persistent Storage

- MongoDB: mongodump and mongorestore via Kubernetes CronJob; dumps written to MinIO
- PVCs: VolumeSnapshot API for stateful workloads; all StatefulSets must declare explicit PVC manifests; MinIO backed up to LocalStack S3 or real AWS S3

Next Meeting

- Agenda: Review architecture diagram; validate Istio and WAF integration; confirm feature flag selection; review CronJob backup pipeline results
-